

CRT Study Guide

CREST Registered Penetration Tester (CRT) - Comprehensive Study Guide

Mapped to CREST CRT Syllabus v2.0 (SYL_CRT_v2.0, 2023-07-07) and the official CRT “Top Tips” document.

1. Exam Overview

Item	Detail
Duration	2 hours 30 minutes practical + 15 minutes reading time
Delivery	Pearson VUE test centre, locked-down Kali Linux VM (no internet, no personal devices)
Prerequisite	Valid CREST Practitioner Security Analyst (CPSA)
Format	Practical “assault course” – mix of flags, short-form answers, and multiple choice
Total marks	160
Pass mark	Must score $\geq 60\%$ in each section (Infrastructure AND Web App)
Retake	8-week wait; results in ~5 working days
Copy/paste	Disabled between Kali and the answer sheet – type answers carefully
Custom files	Can be pre-uploaded via CRESTDrive ($\leq 100\text{MB}$)

Format

The CRT is a **practical assault course** combined with multiple choice and short-form questions. Question formats encountered:

- **Multiple choice** – knowledge questions about tools, protocols, vulnerabilities
- **Short form** – brief written answers
- **Trophy answers** – specific values (banner strings, hashes, file contents, etc.) captured by performing tasks against the reference network

Mark counts and per-section thresholds are **not published by CREST** for the CRT. The auto-marker scores answers and a pass/fail outcome is returned within ~5 working days.

Time budget: ~6 minutes per question on average across an estimated 20-25 questions in 150 minutes. Use the 15-min reading time to plan question order and identify the cheap multiple choice wins.

2. Exam Environment - Tools You Will Have

The exam Kali VM is an exact copy of the publicly available CRT AMI (AWS image), with **Burp Suite Professional** and **Nessus Professional** fully licensed (the public AMI has these installed but unlicensed).

Confirmed / Expected Tools in the Exam VM

Scanning & Enumeration `nmap`, `masscan`, `rustscan`, `netdiscover`, `arp-scan`, `fping`, `enum4linux`, `enum4linux-ng`, `smbclient`, `smbmap`, `rpcclient`, `nbtscan`, `onesixtyone`, `snmpwalk`, `snmp-check`, `ldapsearch`, `windapsearch`, `ike-scan`, `showmount`, `dig`, `dnsenum`, `dnsrecon`, `fierce`, `host`, `whois`, `ssllscan`, `sslyze`, `testssl.sh`, `nikto`, `whatweb`

Vulnerability Assessment `Nessus Professional` (licensed in exam), `nmap NSE scripts`, `searchsploit`

Exploitation `Metasploit Framework` (`msfconsole`, `msfvenom`), `Impacket suite` (`psexec.py`, `secretsdump.py`, `wmiexec.py`, `smbexec.py`, `GetNPUsers.py`, `GetUserSPNs.py`, `ntlmrelayx.py`), `CrackMapExec` / `netexec (nxc)`, `Responder`, `evil-winrm`, `medusa`, `hydra`, `ncrack`

Password Attacks `john` (John the Ripper), `hashcat`, `hash-identifier`, `hashid`, common wordlists in `/usr/share/wordlists` (rockyou.txt, seclists)

Web Application `Burp Suite Professional` (no extensions), `sqlmap`, `ffuf`, `feroxbuster`, `gobuster`, `dirb`, `wfuzz`, `wpscan`, `commix`, `xsasser`

Traffic / Network `tcpdump`, `wireshark`, `tshark`, `ettercap`, `bettercap`, `chisel`, `sshuttle`, `ligolo-ng`, `proxychains`, `socat`

Post-Exploitation / Windows `mimikatz` (Windows-side), `BloodHound` / `SharpHound`, `kerbrute`, `rubeus` (may require upload), Powersploit scripts

Utilities `tmux`, `screen`, `grep`, `awk`, `sed`, `curl`, `wget`, `netcat` (`nc`, `ncat`), `openssl`, `base64`, `xxd`

Pro tip from CREST: Pre-upload to CRESTDrive: custom wordlists, scripts, a personal cheat sheet file, and any static binaries (e.g., `linpeas.sh`, `winpeas.exe`, `chisel`, `ligolo`).

3. Complete Syllabus Breakdown (Appendices A-H)

Appendix A - Core Technical Skills (PT002)

ID	Skill	What You Must Demonstrate
A1	Using Tools and Interpreting Outputs	Select appropriate tool, interpret output from port scans, vuln scans, enumeration, exploitation, traffic capture
A2	OS Fingerprinting	Both active (nmap <code>-O</code> , <code>-A</code>) and passive (p0f, TTL/TCP window inspection) techniques

Study focus: Know the difference between `-sS`, `-sT`, `-sU`, `-sV`, `-sC`, `-A`, `-O`, `-Pn`, `-n`, `-T<0-5>`, `-p-`, `--top-ports`, `--script`.

Appendix B - Internet Information Gathering & Reconnaissance (PT003)

ID	Skill	What You Must Demonstrate
B1	DNS	Querying SOA, NS, MX, A, AAAA, CNAME, PTR, TXT (incl. DMARC), HINFO, SRV. Zone transfers, passive DNS, dangling DNS / subdomain takeover .

Study focus: - `dig axfr @<ns> <domain>` for zone transfer - `dig +short TXT _dmarc.<domain>` - Subdomain takeover indicators (dangling CNAMEs to de-provisioned cloud resources) - Tools: `dig`, `host`, `nslookup`, `dnsenum`, `dnsrecon`, `fierce`

Appendix C - Networks (PT004)

ID	Skill	Key Focus
C1	IPv4	Protocol basics, static/DHCP config, host discovery (ARP, ICMP), routing, ICMP/IGMP/TCP/UDP, IPsec awareness
C2	Network Connections	Ethernet (copper/fibre), Wi-Fi 802.11 a/b/g/n/ac/ax, Ethernet VLANs
C3	VLAN Tagging	IEEE 802.1Q, security implications, connect to a specific VLAN from Linux AND Windows , analyse VLAN-tagged traffic
C4	Traffic Analysis	Capture to PCAP, analyse to recover credentials, analyse stored PCAPs
C5	Network Filtering	Firewalls, where filtering happens, bypass techniques
C6	Network Devices	Configuration analysis of routers, switches, firewalls (Cisco-heavy)
C7	Network Mapping	traceroute, ping, DNS/SNMP queries → produce a logical diagram; identify hosts matching criteria (all FTP servers, all Cisco routers)
C8	TCP	States, SYN/Connect, FIN/NULL/XMAS scans
C9	UDP	States, active UDP service discovery
C10	Host Discovery	Active + passive fingerprinting
C11	Service Identification	Banner inspection, service/version, unknown service evaluation

VLAN hopping – exam-critical:

```
# Linux - tag a VLAN on interface eth0, VLAN 100
modprobe 8021q
ip link add link eth0 name eth0.100 type vlan id 100
ip addr add 10.10.100.5/24 dev eth0.100
ip link set dev eth0.100 up
```

Routing manipulation (new in v2 – 20 marks): - Adding static routes: `ip route add 10.10.20.0/24 via 10.10.10.1` - Source routing awareness - Pivoting via `sshuttle`, `chisel`, SSH dynamic port forwarding (`-D`), Metasploit `autoroute`

Appendix D - Network Services (PT005)

ID	Service	Key Assessment Areas
D1	TLS/SSL	Cipher suites, cert roles, identify insecure configurations (weak ciphers, deprecated protocols, expired/self-signed certs, Heartbleed, POODLE, FREAK)
D2	Unencrypted Services	Telnet, FTP, SNMP (v1/v2c), HTTP – capture credentials
D3	Name Resolution	DNS, NetBIOS/WINS, LLMNR, mDNS – Responder-style poisoning
D4	FTP	Anonymous access, access control, arbitrary file up/download
D5	IPsec	Enumerate & fingerprint with ike-scan
D6	Management Services	Telnet, Cisco reverse telnet, SSH, HTTP, PowerShell Remoting, WMI, WinRM
D7	Desktop Access	RDP, VNC, XDMCP, X
D8	SSH	Versions, fingerprinting, trust relationships, authorized_keys abuse, authentication mechanisms
D9	TFTP	Arbitrary file read/write, Cisco config extraction/replacement
D10	SNMP	v1/v2c/v3 differences, MIB, enumerate users/processes/network config, Cisco config extraction
D11	NFS	Exports, SUID-root files, UID/GID manipulation, root_squash / nosuid / noexec , host & file-level restrictions
D12	SMB	Windows shares, Samba, share identification & analysis
D13	LDAP	AD vs OpenLDAP, enumerate usernames/groups/system names
D14	Berkeley r-services	rsh , rlogin , rexec , .rhosts , /etc/hosts.equiv , rwho , rusers
D15	X Windows	Screenshots, keystroke capture, command injection, host vs user access control
D16	NTP	Function, importance for logging/auth, information extraction
D17	Finger	Username enumeration via finger daemon
D18	RPC	Enumeration, common services, recent vulnerabilities
D19	SMTP/Mail	EXPN / VRFY enumeration, Postfix/Exchange vulns, mail relaying

Appendix E - Microsoft Windows Security Assessment (PT006/007)

ID	Skill	Key Focus
E1	Windows Reconnaissance	Identify Windows hosts, forests/domains/DCs/workgroups, shares, browse lists
E2	AD Enumeration	Users, groups, computers, trusts , SPNs , password policies
E3	Windows Network Enumeration	NetBIOS, LDAP, SNMP, RID cycling
E4	Registry	Detect/manipulate weak registry ACLs, extract data from keys
E5	Windows File Permissions	Insecure NTFS permissions → privesc
E6	Windows Remote Exploitation	OS + 3rd party app remote exploits
E7	Windows Processes	Running processes, DLL loading privesc (DLL hijacking)
E8	Windows Passwords	Hashing algorithms (LM, NTLM, NetNTLMv1/v2, Kerberos), storage, offline cracking (dict, brute, rainbow tables)
E9	Windows Post-Exploitation	Hash/cred extraction (SAM, LSA, cached), plaintext hunt, cracking, patch levels, missing-patch derivation, reversion, lateral/horizontal movement
E10	Windows Local Exploitation	Local privesc via file/service permissions
E11	Windows Patch Management	SMS, SUS, WSUS
E12	Windows Desktop Lockdown (20 marks!)	Break out of locked-down desktop / Citrix , privesc from desktop – CREST explicitly says <i>no external tools, living off the land</i>
E13	Common Windows Applications	Public exploit code for known vulns

Desktop lockdown “living off the land” – critical exam area: - File dialogs (Open/Save As) → address bar → `cmd.exe`, `powershell.exe`, `\\127.0.0.1\C$` - Help (F1) → jump to IE/Edge → address bar tricks - Right-click + Shift, sticky keys (`sethc.exe`), accessibility features - Registry editor via `regedit.exe` launched from dialog - PowerShell ISE, Task Manager “File → Run new task” - Environment variables, known folder paths, `%comspec%` - Group Policy bypass: direct registry edit, `gpresult /r`

Appendix F - Linux / UNIX Security Assessment (PT007)

ID	Skill	Key Focus
F1	Linux Reconnaissance	Identify *nix hosts
F2	Linux Network Enumeration	NFS, SMB, SMTP, SSH, Telnet, SNMP, rusers/rwho/finger, RPC
F3	Linux Passwords	<code>/etc/passwd</code> , <code>/etc/shadow</code> , <code>/etc/group</code> , <code>/etc/gshadow</code> format, hashing algorithms (\$1\$ MD5, \$5\$ SHA-256, \$6\$ SHA-512, \$y\$ yescrypt), offline cracking, physical access recovery
F4	Linux Processes	Running processes, shared library loading privesc (LD_PRELOAD, LD_LIBRARY_PATH, rpath)
F5	Linux File Permissions	Find insecure/unusual perms, SUID/SGID hunting , capabilities
F6	Linux Remote Exploitation	Solaris, Linux, FreeBSD, OpenBSD
F7	Linux Local Exploitation	Local privesc via perms
F8	Linux Post-Exploitation	Plaintext creds, password exfil + crack, lateral movement , patch levels, missing patches, reversion

Key enumeration commands:

```
# SUID hunt
find / -perm -4000 -type f 2>/dev/null
# Capabilities
getcap -r / 2>/dev/null
# Writable cron
ls -la /etc/cron* /var/spool/cron/
# Writable PATH dirs, sudo rules
sudo -l
# GTFOBins lookup (know the top 20 binaries)
```

Appendix G - Web Technologies (PT008) - 23 skill areas (G1-G23)

ID	Skill	Key Focus
G1	Web Servers	Identify, fingerprint, remote exploit, virtual hosts / multiple ports / app-specific URLs , web proxies
G2	Common Web Applications	Identify & exploit well-known vulns (WordPress, Joomla, Drupal, Tomcat, Jenkins, phpMyAdmin)
G3	Web App Frameworks	.NET, J2EE, ColdFusion, Ruby on Rails, NodeJS, Django, Flask – known vulns
G4	Web Protocols	HTTP, HTTPS, WebSockets , all HTTP methods (GET/POST/PUT/DELETE/OPTIONS/TRACE/PATCH/HEAD), response codes, security headers (HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy)
G5	Markup Languages	HTML, XHTML, XML
G6	Information Gathering	Error messages leak info
G7	Web App Recon	Mark-up/code analysis: hidden fields, DB strings, creds, dev comments, external/auth-only URLs; spidering, forced browsing, client-side code
G8	Web Authentication	HTML forms, Kerberos, NTLM, OpenID Connect, SAML; vulns: unencrypted transport, username enum, brute force, auth bypass, insecure password reset, weak logout/timeout, weak CAPTCHA, race conditions, lack of MFA
G9	Web Authorisation	IDOR, privilege escalation, horizontal/vertical access control
G10	Input Validation	Allow-list vs deny-list vs sanitisation; server-side required , client-side flaws
G11	XSS	Persistent / Reflected / DOM-based; arbitrary JS to steal cookies/data
G12	Cookies	Attributes: Secure , HttpOnly , SameSite , Path , Domain , Expires
G13	Sessions	Session control mechanisms, ID location, IDs-in-URL risks, harvest + analyse IDs for predictability/entropy
G14	SQL Injection	Detect classic SQLi, blind SQLi (boolean & time-based), execute arbitrary SQL
G15	Mail Injection	SMTP injection, IMAP injection
G16	OS Command Injection	Identify, prove, exploit
G17	Session Hijacking	Identify + exploit
G18	CSRF	Identify + exploit, role of sessions in CSRF
G19	File Uploads	Common vulns, MIME-type role, generate malicious payloads in multiple formats
G20	Parameter Manipulation	Client-side proxy tampering
G21	Web App Logic Flaws	Functional logic, function access control, business logic
G22	Web Cryptography	Protect data in transit & at rest; TLS best practice; identify + exploit encoded values (Base64) and crypto values (MD5 hashes)
G23	Directory Traversal	Identify + exploit

Appendix H - Databases (PT009)

ID	DBMS	Key Focus
H1	SQL Relational (general)	SQL interaction, extract data (SQLite, PostgreSQL etc.), connection/auth methods, connection strings (JDBC, ODBC)
H2	Microsoft SQL Server	Remote exploit, default creds, data extraction, <code>xp_cmdshell</code> , system commands, privesc, filesystem r/w
H3	MySQL	Remote exploit, default creds, version/patch fingerprint, system commands, privesc, filesystem r/w, UDF exploitation
H4	Oracle RDBMS	Remote exploit, TNS Listener , default creds, data extraction, version/patch fingerprint, system commands, privesc, filesystem r/w
H5	PostgreSQL	Remote exploit, default creds, version/patch fingerprint, system commands (<code>COPY FROM PROGRAM</code>), privesc, filesystem r/w

4. Study Plan (4-Week Outline)

Week 1 - Foundations & Infrastructure Recon

- Re-read full CRT Syllabus v2.0 and Top Tips PDF
- Download CRT Kali AMI from CREST and set up offline
- Practice nmap (all scan types), masscan, Nessus – drill muscle memory
- DNS enumeration drills (dig, dnsrecon, zone transfers)
- SMB/SNMP/LDAP/NFS enumeration labs

Week 2 - Exploitation & AD

- Metasploit as both exploit AND enumeration/client tool
- Impacket suite (secretsdump, psexec, GetNPUsers, GetUserSPNs, ntlmrelayx)
- CrackMapExec/NetExec workflows
- Windows desktop lockdown breakouts (practice 10+ techniques)
- Linux privesc (GTFOBins, SUID, capabilities, cron, sudo)
- HackTheBox “Starting Point” + retired easy boxes

Week 3 - Web Application

- Burp Suite Pro workflows (Proxy → Target → Intruder → Repeater → Decoder → Comparer)
- OWASP Juice Shop end-to-end
- DVWA / bWAPP / WebGoat – low + medium
- Manual SQLi, then sqlmap; XSS variants; directory traversal; file upload
- PortSwigger Web Security Academy (Labs: SQLi, XSS, Auth, Access Control, CSRF, File Upload, Command Injection, Directory Traversal)

Week 4 - Timed Mocks & Weak Spots

- Two 90-minute timed mocks per week (one discovery-heavy, one exploitation-heavy)
- Time every enumeration step – know how long your workflow actually takes
- Practice **without internet** – only `man` pages, `--help`, and your offline notes
- Rehearse typing exam answers (no copy/paste, watch for trailing whitespace)
- Finalise and upload your personal cheat sheet to CRESTDrive

5. Recommended Supplementary Resources

Books - *The Hacker Playbook 3* – Peter Kim - *Red Team Field Manual (RTFM)* – Ben Clark - *The Web Application Hacker's Handbook (2e)* – Stuttard & Pinto - *Penetration Testing: A Hands-On Introduction* – Georgia Weidman

Free online - PortSwigger Web Security Academy (best free web training) - HackTricks (<https://book.hacktricks.xyz>) - PayloadsAllTheThings (GitHub) - GTFOBins & LOLBAS (Living Off The Land Binaries And Scripts) - OWASP Testing Guide v4.2

Labs - HackTheBox (CREST CRT path exists), TryHackMe (Jr Penetration Tester path) - VulnHub (offline VMs) - OffSec Proving Grounds (great for timed practice)

6. Exam-Day Strategy

Reading time (15 min): 1. Read every question first – identify which need long scans. 2. Start Nessus + nmap `-p-` against infrastructure targets *immediately* at exam start. 3. Note which questions have the highest marks (`1 minute per mark` budget).

During the exam: - New terminal per host → `tee / script` terminal output to a file for later grep. - Don't chase vulnerabilities that aren't asked for – answer the question and move on. - If stuck > 10 minutes, mark it and move on. Come back after easier wins. - For desktop lockdown: **no external tools**. Think “living off the land.” - For web: Burp Pro has no extensions – your own methodology matters more than tooling.

Flag formatting: - Type carefully (no copy/paste). Watch for: - Trailing spaces / newlines - Case sensitivity - Expected format (e.g., `user:pass`, hash only, full path)

Common pitfalls (from candidate reviews): - Kali VM can be slow – factor this into scan times - Running out of time on web app section (leave ≥ 45 min for it) - Forgetting Metasploit can be used as a *client* (brute-force, enumeration), not just an exploit framework - Over-reliance on internet-sourced payloads – rehearse from memory / local notes

Good luck – the CRT rewards methodical, time-aware testers who've actually done the work. Trust your process.